

Compte rendu complet des travaux pratiques de test intrusion

Préparation de Kali Linux et phase de reconnaissance

BTS SIO deuxième année option SISR

Année scolaire 2026 2027

Périmètre autorisé

Machines virtuelles du laboratoire et serveur pédagogique btssiogap.com

Sommaire

Sommaire.....	2
Présentation et objectifs.....	2
TP 1.1 Téléchargement de Kali Linux et VirtualBox.....	4
TP 1.3 Installation des Additions invité.....	5
TP 2.1 Méthodologie du test d'intrusion.....	7
TP 2.2 Préparation des machines et du réseau.....	8
TP 2.3 Phase de reconnaissance.....	12
Mise en service de SpiderFoot.....	13
Exercice 7 Scan du serveur web autorisé.....	15
Bilan des travaux réalisés.....	17
Conclusion.....	18

Présentation et objectifs

Ces travaux pratiques ont pour objectif de préparer un laboratoire de test d'intrusion, de comprendre la méthodologie d'un audit de sécurité et de réaliser une première phase de reconnaissance. Le laboratoire comprend une machine Kali Linux utilisée comme poste de test et une machine Windows 7 utilisée comme cible locale. La partie finale porte sur un serveur web pédagogique explicitement autorisé par l'enseignant.

Le résultat principal est la mise en place d'un environnement fonctionnel : la machine Kali Linux atteint la machine Windows 7 sur le réseau du laboratoire, la documentation est organisée dans CherryTree et SpiderFoot a commencé à collecter des informations publiques sur le domaine autorisé.

Élément	Valeur
Machine de test	Kali Linux 64 bits
Machine cible locale	Windows 7
Hyperviseur	Oracle VM VirtualBox
Réseau du laboratoire	172.30.0.0/16
Serveur web autorisé	btssiogap.com
Outils principaux	Terminal, CherryTree et SpiderFoot

TP 1.1 Téléchargement de Kali Linux et VirtualBox

Objectif

L'objectif est de disposer d'un système Kali Linux isolé dans une machine virtuelle. Kali regroupe les outils nécessaires aux tests de sécurité, tandis que VirtualBox permet d'exécuter plusieurs systèmes sans modifier directement le poste physique.

Étapes réalisées

- Téléchargement de l'image ISO officielle de Kali Linux en version 64 bits.
- Téléchargement puis installation de VirtualBox sur le poste hôte.
- Création d'une nouvelle machine virtuelle nommée kali, de type Linux 64 bits (Ubuntu 64-bit dans VirtualBox).
- Attribution de 2 Go de mémoire vive et création d'un disque virtuel de 25 Go.
- Démarrage sur l'image ISO et installation de Kali Linux.
- Création du compte utilisateur yoann (nom de la machine : yoann) puis vérification du démarrage du système.

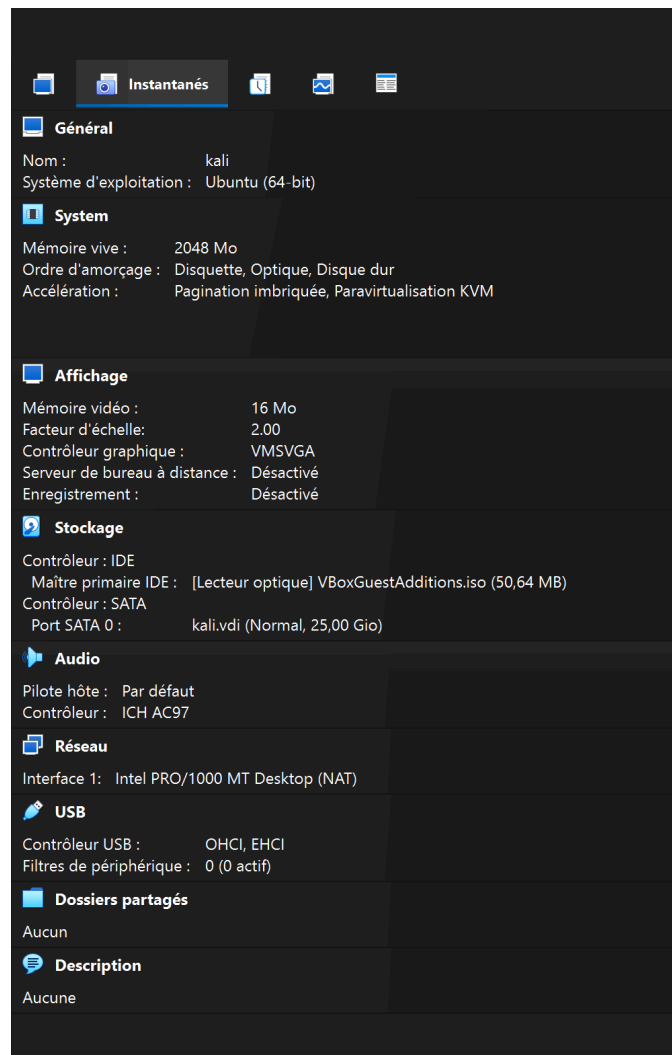


Figure 1 Caractéristiques de la machine virtuelle Kali Linux

La capture montre la machine virtuelle nommée kali, de type Ubuntu (64-bit), avec 2 048 Mo de mémoire vive, 16 Mo de mémoire vidéo (contrôleur graphique VMSVGA) et un disque kali.vdi de 25,00 Gio sur le

contrôleur SATA. L'image VBoxGuestAdditions.iso est insérée dans le lecteur optique IDE et la carte réseau (Intel PRO/1000 MT Desktop) est encore en mode NAT sur cette capture. Cette configuration est suffisante pour les outils utilisés dans ce TP.

Mise à jour du système

Après l'installation, les listes de paquets et le système ont été mis à jour avec les commandes suivantes :

```
sudo apt update
sudo apt dist-upgrade
```

Cette opération permet d'obtenir les dernières corrections et versions disponibles dans les dépôts configurés.

TP 1.3 Installation des Additions invité

Rôle des Additions invité

Les Additions invité ajoutent des pilotes et des fonctions d'intégration entre VirtualBox et Kali Linux. Elles améliorent notamment l'affichage, le redimensionnement de la fenêtre, la souris et, lorsque VirtualBox est correctement configuré, le presse-papiers partagé.

Procédure suivie

- Dans la fenêtre de la machine virtuelle, ouverture du menu Périphériques.
- Sélection de Insérer l'image CD des Additions invité.
- Ouverture du lecteur virtuel apparu dans Kali Linux.
- Ouverture d'un terminal dans le dossier du lecteur.
- Passage en administrateur puis lancement du programme d'installation.
- Redémarrage de la machine virtuelle pour appliquer les modifications.

```
sudo su
sh VBoxLinuxAdditions.run
reboot
```

Après le redémarrage, le système est prêt pour la suite du laboratoire. Le copier-coller entre l'hôte et la machine virtuelle dépend également du réglage Périphériques, Presse-papiers partagé, Bidirectionnel.

Configuration de la carte réseau VirtualBox

La figure 1 montrait encore une carte réseau en mode NAT. L'adaptateur 1 de la machine Kali a ensuite été placé en mode accès par pont (Attached to : Accès par pont) sur l'interface Intel(R) Wi-Fi 6E AX211 160MHz du poste hôte. La carte virtuelle est de type Intel PRO/1000 MT Desktop (82540EM), le mode promiscuité est réglé sur Refuser et le câble virtuel est connecté. Dans ce mode, la machine virtuelle apparaît sur le même réseau que les autres postes du laboratoire.

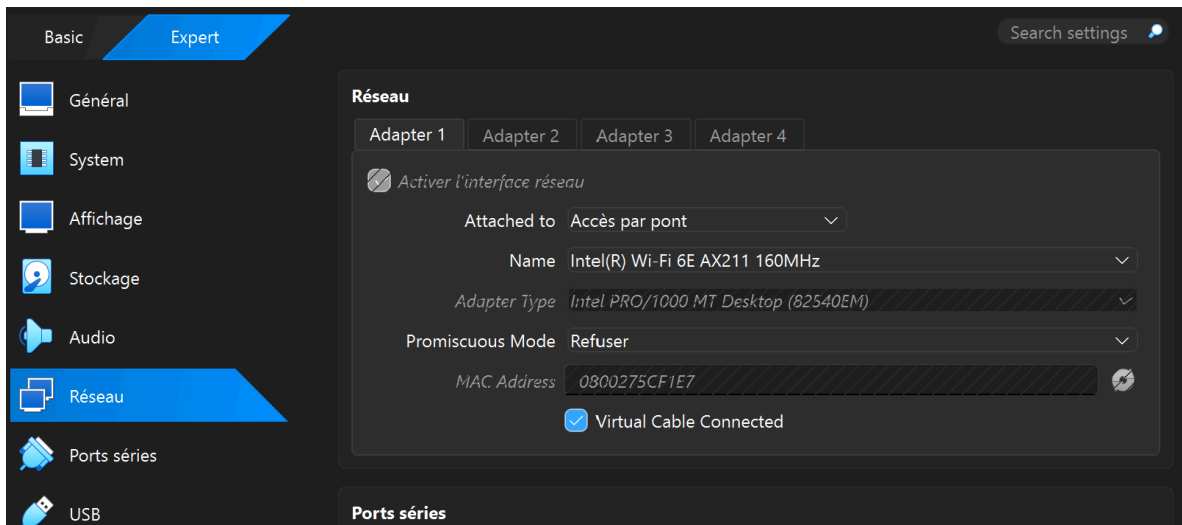


Figure 2 Carte réseau VirtualBox configurée en accès par pont

TP 2.1 Méthodologie du test d'intrusion

Un test d'intrusion doit suivre une méthode et un périmètre précis. L'autorisation du propriétaire est indispensable avant toute analyse active. Les principales méthodes de référence étudiées sont OWASP, PTES, OSSTMM et NIST.

Référence	Rôle
OWASP	Bonnes pratiques et méthodes de sécurité des applications web.
PTES	Standard structurant les différentes phases d'un test d'intrusion.
OSSTMM	Méthode de test de sécurité opérationnelle mesurable.
NIST	Cadres et recommandations de cybersécurité et de gestion des risques.

Méthode retenue pour les TP

Étape	But
Négociation	Définir l'autorisation, les cibles, les limites et les règles d'engagement.
Reconnaissance	Collecter des informations sur la cible de manière passive ou active.
Scanning	Identifier les hôtes, ports, services et éléments techniques exposés.
Gain d'accès	Tester une exploitation uniquement si elle est autorisée.
Maintien d'accès	Évaluer la possibilité de conserver un accès dans le périmètre prévu.
Nettoyage	Retirer les fichiers et modifications créés pendant le test.
Rapport	Présenter les actions, preuves, résultats, risques et recommandations.

Dans les travaux réalisés ici, nous nous sommes arrêtés à la reconnaissance et au scan autorisé. Aucune exploitation ni tentative d'accès à la base de données n'a été réalisée.

TP 2.2 Préparation des machines et du réseau

Architecture du laboratoire

Machine	Adresse IPv4	Masque	Passerelle
Kali Linux	172.30.16.102	255.255.0.0	172.30.255.254
Windows 7	172.30.13.103	255.255.0.0	172.30.255.254

Les deux machines appartiennent au réseau 172.30.0.0/16 et utilisent la même passerelle. Elles ont été configurées en accès par pont afin de communiquer sur le réseau du laboratoire.

Configuration de Kali Linux

Dans les paramètres IPv4 de la connexion filaire (Wired connection 1), la méthode manuelle a été sélectionnée. L'adresse 172.30.16.102, le masque 255.255.0.0 et la passerelle 172.30.255.254 ont été saisis. Le serveur DNS 172.17.63.131 est également renseigné.

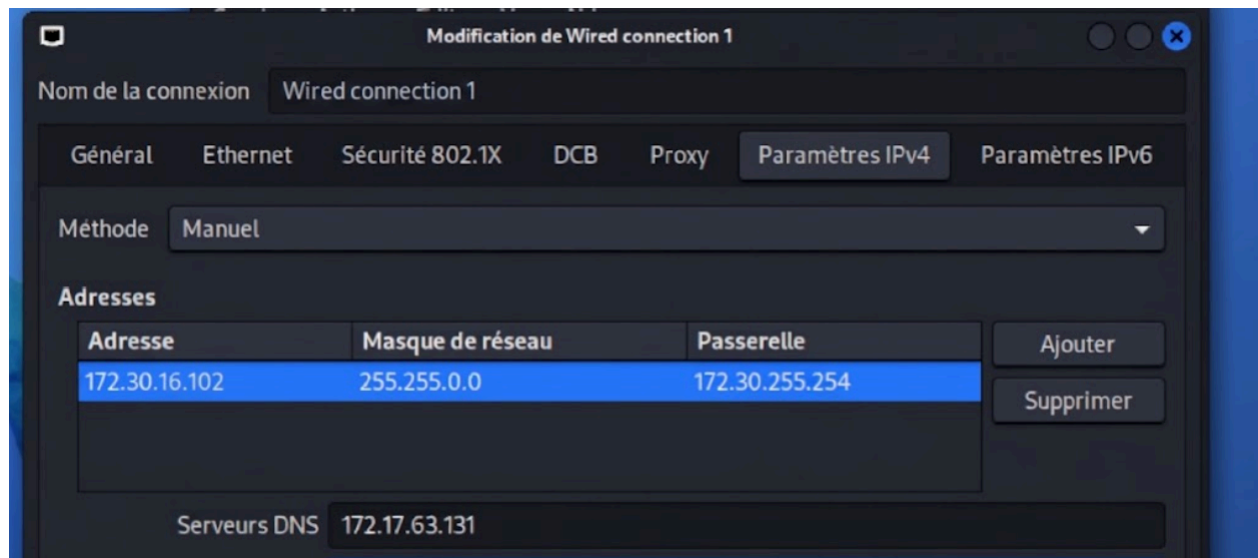


Figure 3 Paramètres IPv4 manuels de Kali Linux

La commande `ip a` a ensuite permis de vérifier l'adresse appliquée sur l'interface `eth0`, à l'état UP : la capture affiche 172.30.16.102/16 avec l'adresse de diffusion 172.30.255.255. L'adresse MAC 08:00:27:5c:f1:e7 correspond à celle de la carte virtuelle visible sur la figure 2.

`ip a`

```
yoann@yoann: ~  
Session Actions Éditer Vue Aide  
(yoann@yoann)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def  
ault qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g  
roup default qlen 1000  
    link/ether 08:00:27:5c:f1:e7 brd ff:ff:ff:ff:ff:ff  
    inet 172.30.16.102/16 brd 172.30.255.255 scope global noprefixroute eth0  
        valid_lft forever preferred_lft forever  
    inet6 fd17:625c:f037:2:6391:3936:1cdf:af5f/64 scope global temporary dyna  
mic  
        valid_lft 86381sec preferred_lft 14381sec  
    inet6 fd17:625c:f037:2:5051:a9d6:21aa:c13a/64 scope global dynamic mngtmp  
addr noprefixroute  
        valid_lft 86381sec preferred_lft 14381sec  
    inet6 fe80::1420:b082:e8fb:5d7/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(yoann@yoann)-[~]  
$
```

Figure 4 Vérification de l'adresse IPv4 de Kali Linux

Configuration et test de Windows 7

Sur Windows 7, la commande ipconfig affiche pour la carte Ethernet « Connexion au réseau local » l'adresse IPv4 172.30.13.103, le masque 255.255.0.0 et la passerelle 172.30.255.254. Cette configuration est cohérente avec celle de Kali Linux : même réseau 172.30.0.0/16 et même passerelle.

```
Carte Ethernet Connexion au réseau local :
    Suffixe DNS propre à la connexion. . . :
    Adresse IPv6 de liaison locale. . . . : fe80::dd46:1df8:772d:c1a%11
    Adresse IPv4. . . . . : 172.30.13.103
    Masque de sous-réseau. . . . . : 255.255.0.0
    Passerelle par défaut. . . . . : 172.30.255.254

Carte Tunnel isatap.{0C555987-1440-4EC1-ABF3-8E03679DE78D} :
    Statut du média. . . . . : Média déconnecté
```

Figure 5 Vérification de la configuration IPv4 de Windows 7

Tests de connectivité

Un premier test a été lancé depuis l'invite de commandes de Windows 7 (session fahad) avec la commande ping sur l'adresse 172.30.13.103, celle que ipconfig vient d'afficher. Les quatre réponses ont été reçues en moins de 1 ms, avec un TTL de 128 et 0 % de perte : la pile réseau de Windows 7 fonctionne correctement.

ping 172.30.13.103

```
C:\Users\fahad>ping 172.30.13.103

Envoi d'une requête 'Ping' 172.30.13.103 avec 32 octets de données :
Réponse de 172.30.13.103 : octets=32 temps<1ms TTL=128
Réponse de 172.30.13.103 : octets=32 temps<1ms TTL=128
Réponse de 172.30.13.103 : octets=32 temps<1ms TTL=128
Réponse de 172.30.13.103 : octets=32 temps<1ms TTL=128

Statistiques Ping pour 172.30.13.103:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
    Durée approximative des boucles en millisecondes :
        Minimum = 0ms, Maximum = 0ms, Moyenne = 0ms

C:\Users\fahad>$_
```

Figure 6 Ping réussi depuis Windows 7 sur l'adresse 172.30.13.103

Le test depuis Kali Linux vers Windows 7 a d'abord échoué lorsque le pare-feu Windows bloquait les requêtes ICMP. Après la désactivation du pare-feu par l'enseignant dans le cadre du laboratoire, les quatre paquets envoyés ont été reçus : 0 % de perte, TTL de 128 (valeur typique d'un système Windows) et un temps de réponse moyen de 1,65 ms (minimum 1,22 ms, maximum 2,36 ms).

ping -c 4 172.30.16.103

```
(yoann@yoann)-[~]
$ ping -c 4 172.30.16.103
PING 172.30.16.103 (172.30.16.103) 56(84) bytes of data.
64 bytes from 172.30.16.103: icmp_seq=1 ttl=128 time=2.36 ms
64 bytes from 172.30.16.103: icmp_seq=2 ttl=128 time=1.22 ms
64 bytes from 172.30.16.103: icmp_seq=3 ttl=128 time=1.72 ms
64 bytes from 172.30.16.103: icmp_seq=4 ttl=128 time=1.31 ms

--- 172.30.16.103 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3006ms
rtt min/avg/max/mdev = 1.221/1.651/2.359/0.449 ms

(yoann@yoann)-[~]
```

Figure 7 Ping réussi de Kali Linux vers Windows 7 (172.30.16.103)

Conclusion de cette étape : Kali Linux atteint Windows 7 sur le réseau du laboratoire sans aucune perte de paquet. L'adresse de Windows 7 utilisée pour ce test (172.30.16.103) diffère de celle affichée par ipconfig sur la figure 5 (172.30.13.103) ; les deux appartiennent au même réseau 172.30.0.0/16 que Kali. Le laboratoire est donc prêt pour la phase de reconnaissance.

TP 2.3 Phase de reconnaissance

Reconnaissance passive et active

Type	Principe	Exemples
Passive	Collecter des informations publiques sans solliciter directement la cible.	Moteurs de recherche, forums, réseaux sociaux, HackerOne.
Active	Interagir avec la cible autorisée afin d'obtenir des informations techniques.	Ping, SpiderFoot, analyse DNS et scans autorisés.

La reconnaissance passive est plus discrète mais peut fournir moins d'informations techniques. La reconnaissance active est plus riche, mais elle peut être détectée ou bloquée par un pare-feu. Elle ne doit être réalisée que dans un périmètre autorisé.

Repérage des outils disponibles

Dans le menu Kali, la rubrique 01 - Reconnaissance regroupe plusieurs familles d'outils (Analyse de vulnérabilités, Analyse Web, Bluetooth, Informations sur le réseau, Informations sur l'hôte, WiFi) ainsi que des outils comme burpsuite, dirb, dirbuster, ffuf, gobuster, legion, maltego, nmap et recon-ng. SpiderFoot a été retenu pour automatiser la collecte et il est lancé depuis le terminal.

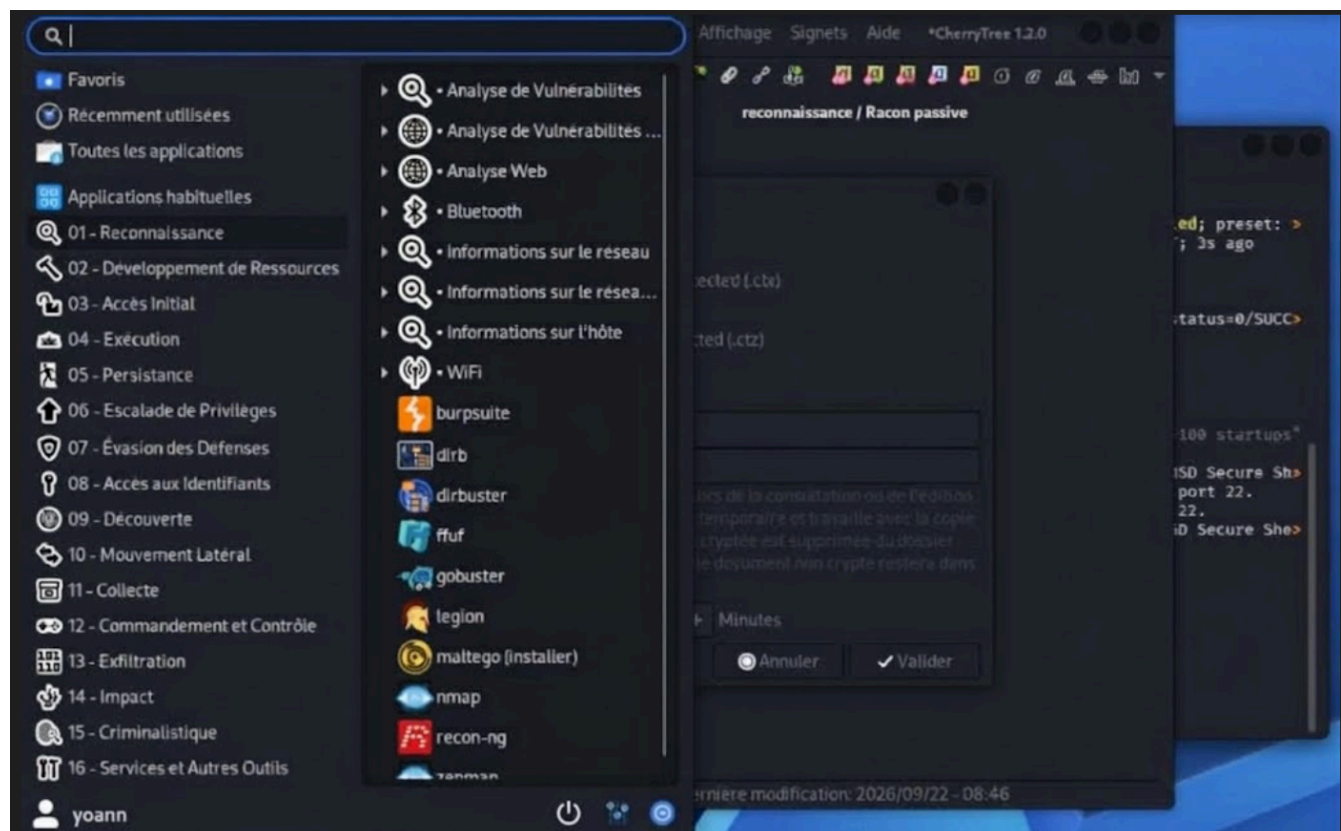


Figure 8 Outils de reconnaissance disponibles dans Kali Linux

Organisation de la documentation dans CherryTree

CherryTree (version 1.2.0) a été utilisé pour classer les notes du test. Deux grandes sections ont été créées : exploitation, qui contient MsFVenom, Metasploit et Maintien, et reconnaissance, qui contient Racon active et Racon passive.

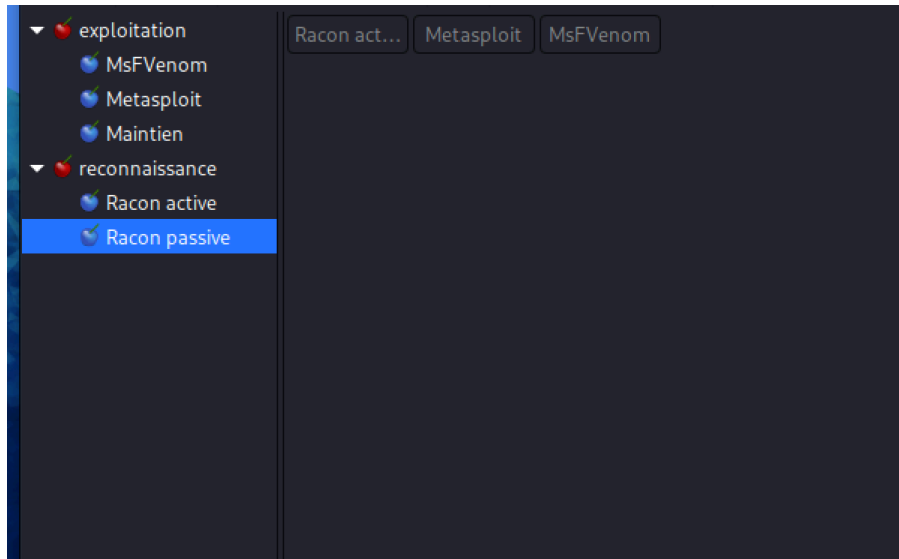


Figure 9 Arborescence de documentation dans CherryTree

Les sous-sections Racon active et Racon passive sont destinées aux notes de reconnaissance active (ping, SpiderFoot) et passive (recherche sur HackerOne). Sur la capture, le nœud Racon passive est sélectionné et sa page est encore vide. Le document est enregistré au format CherryTree afin de conserver l'arborescence.

Mise en service de SpiderFoot

SpiderFoot a été lancé en root depuis le terminal comme service web sur l'adresse de la machine Kali (172.30.16.102, port 80). Le terminal affiche un avertissement : le fichier passwd ne contient aucun mot de passe, l'authentification est donc désactivée. Cela reste acceptable dans un laboratoire isolé, mais il faudrait activer l'authentification dans un autre contexte.

```
spiderfoot -l 172.30.16.102:80
```

```
2 warnings.warn(AST_MULTICAST_UP LOBER_UP> mru 1500 qdisc fn_codel state 1
(root@yoann)-[/home/yoann]
# spiderfoot -l 172.30.16.102:80
2026-09-22 08:57:58,558 [INFO] sf : Starting web server at 172.30.16.102:80
..
2026-09-22 08:57:58,550 [WARNING] sf : scope link uuprefixrpote
*****
Warning: passwd file contains no passwords. Authentication disabled.
Please consider adding authentication to protect this instance!
Refer to https://www.spiderfoot.net/documentation/#security.
*****
(root@yoann)-[~]
#
*****
Use SpiderFoot by starting your web browser of choice and
browse to http://172.30.16.102:80/
*****
```

Figure 10 Démarrage du serveur web SpiderFoot sur 172.30.16.102:80

Le terminal indique l'adresse à ouvrir dans le navigateur de Kali. L'interface SpiderFoot v4.0.0 a été ouverte à l'adresse suivante :

<http://172.30.16.102>

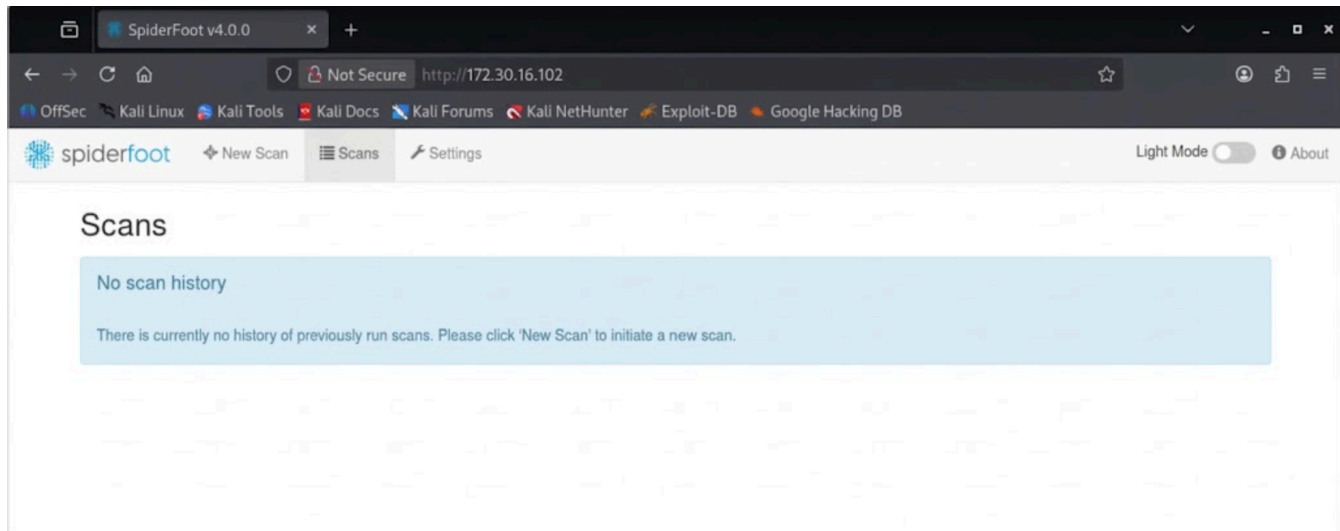


Figure 11 Interface SpiderFoot v4.0.0 sans historique de scan (No scan history)

Résolution du problème accès Internet

Lors du premier lancement, SpiderFoot n'arrivait pas à télécharger le fichier de configuration `effective_tld_names.dat` depuis `publicsuffix.org`. Le journal indiquait `Network is unreachable (Errno 101)`, puis le processus de scan s'arrêtait avec l'erreur `Python TypeError : write() argument must be str, not None`. L'accès direct à Internet n'étant pas possible, le proxy du lycée a été déclaré dans les variables d'environnement.

```
root@yoann: /home/yoann
Session Actions Éditer Vue Aide

2026-09-22 09:12:36,098 [INFO] sflib : Downloading configuration data from: https://publicsuffix.org/list/effective_tld_names.dat
2026-09-22 09:13:05,679 [ERROR] sflib : Unable to open option URL, https://publicsuffix.org/list/effective_tld_names.dat: HTTPSConnectionPool(host='publicsuffix.org', port=443): Max retries exceeded with url: /list/effective_tld_names.dat (Caused by NewConnectionError("HTTPSConnection(host='publicsuffix.org', port=443): Failed to establish a new connection: [Errno 101] Network is unreachable"))
Process Process-2:
Traceback (most recent call last):
  File "/usr/lib/python3.13/multiprocessing/process.py", line 313, in _bootstrap
    self.run()
    ~~~~~^
  File "/usr/lib/python3.13/multiprocessing/process.py", line 108, in run
    self._target(*self._args, **self._kwargs)
    ~~~~~^
  File "/usr/share/spiderfoot/sfscan.py", line 30, in startSpiderFootScanner
    return SpiderFootScanner(*args, **kwargs)
  File "/usr/share/spiderfoot/sfscan.py", line 206, in __init__
    self.__sf.cachePut("internet_tlds", self.__config['internet_tlds'])
    ~~~~~^
  File "/usr/share/spiderfoot/sflib.py", line 291, in cachePut
    fp.write(data)
    ~~~~~^
TypeError: write() argument must be str, not None
```

Figure 12 Erreur `Network is unreachable` observée avant la configuration du proxy

Les commandes suivantes ont été saisies pour déclarer le proxy :

```
export http_proxy="http://172.16.63.130:3128"
export https_proxy="http://172.16.63.130:3128"
export HTTP_PROXY="$http_proxy"
export HTTPS_PROXY="$https_proxy"
source /etc/profile
```

Après cette correction, le scan a démarré. Des erreurs de modules sont toutefois restées présentes lorsque certains services exigeaient une clé API ou un outil externe non configuré.

Exercice 7 Scan du serveur web autorisé

Création du scan

Dans SpiderFoot, un nouveau scan se crée depuis l'onglet New Scan. La capture montre le formulaire avant remplissage : les champs Scan Name et Scan Target sont vides et, dans l'onglet By Use Case, le cas d'usage All est sélectionné par défaut. Pour cet exercice, le cas d'usage Footprint, qui sert à comprendre quelles informations la cible expose sur Internet, est mieux adapté à une collecte d'informations publiques sur le domaine btssiogap.com, alors que All active tous les modules et est beaucoup plus lent. Le scan est ensuite lancé avec le bouton Run Scan Now.

- Ouvrir New Scan dans SpiderFoot.
- Saisir un nom permettant d'identifier clairement le test.
- Saisir btssiogap.com dans le champ Scan Target.
- Choisir le cas d'usage Footprint à la place de All, sélectionné par défaut.
- Lancer le scan et consulter Summary, Correlations, Browse, Graph, Scan Settings et Log.

Figure 13 Formulaire de création d'un nouveau scan SpiderFoot

Informations récoltées

Au moment de la capture, le scan nommé rr était encore en cours (statut RUNNING). SpiderFoot affichait 26 éléments collectés, dont 25 uniques, pour 100 erreurs de modules. Le graphique Data Types montre que la collecte DNS et réseau a fonctionné. Les résultats ci-dessous sont donc un état provisoire et non un résultat définitif.

Information visible	Interprétation
26 éléments au total	Nombre d'événements collectés au moment de la capture.
25 éléments uniques	Presque tous les éléments collectés étaient distincts.
Noms Internet affiliés	Noms ou hôtes associés au domaine analysé : catégorie la plus importante, environ 28 % des éléments uniques (dont 4 % de noms non résolus).
Enregistrements DNS SPF et TXT	Informations publiées dans la zone DNS du domaine, environ 4 % chacun.
Nom de domaine et domaine parent	Identification de la cible et de sa hiérarchie DNS, environ 4 % chacun.
Passerelles de messagerie MX	Serveurs déclarés pour la réception des courriels, environ 20 % des éléments uniques.
Adresses IP et noms associés	Correspondances entre noms DNS et adresses réseau (IP Address : 4 %, Internet Name : 8 %).
Serveurs de noms NS	Serveurs DNS faisant autorité pour le domaine, environ 8 %.
Enregistrements DNS bruts	Données DNS collectées directement par les modules, environ 12 %.

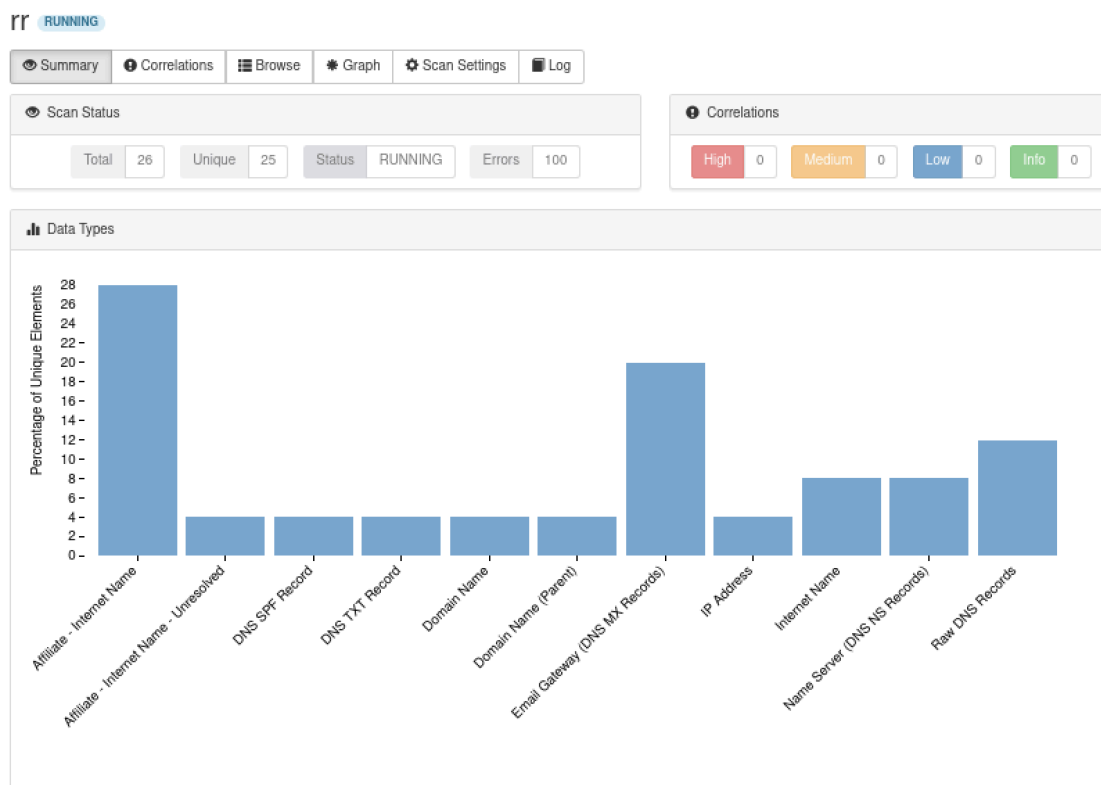


Figure 14 Résultats provisoires du scan « rr » dans SpiderFoot (26 éléments, 100 erreurs)

Analyse des erreurs

Le compteur indiquait 100 erreurs au moment de la capture. Cela ne signifie pas que le serveur présente 100 vulnérabilités. Dans SpiderFoot, de nombreux modules dépendent de clés API, d'outils additionnels ou de services externes. Une erreur de module indique donc principalement qu'une source n'a pas pu être interrogée. Les corrélations High, Medium, Low et Info étaient toutes à zéro ; aucune vulnérabilité ne peut être affirmée à partir de cette capture.

Bilan des travaux réalisés

Travail	Résultat
Installation de Kali et VirtualBox	Machine Kali opérationnelle dans VirtualBox.
Additions invité	Intégration et confort d'utilisation améliorés.
Préparation de Windows 7	Machine cible locale installée et adressée.
Configuration réseau	Kali 172.30.16.102 ; Windows 7 172.30.13.103 (ipconfig) et 172.30.16.103 (ping depuis Kali), sur le même réseau /16.
Test local sur Windows 7	Ping de 172.30.13.103 réussi : 4 réponses, TTL 128, 0 % de perte.
Test Kali vers Windows	Réussi après adaptation du pare-feu : 4 réponses, 0 % de perte, 1,65 ms en moyenne.

Documentation CherryTree	Arborescence reconnaissance (active, passive) et exploitation créée.
SpiderFoot	Interface démarrée sur 172.30.16.102 et accès Internet rétabli grâce au proxy.
Exercice 7	Scan de reconnaissance autorisé de btssiogap.com lancé : 26 éléments collectés au moment de la capture.

Difficultés rencontrées et solutions

Difficulté	Cause	Solution
Ping impossible dans un sens	Pare-feu Windows bloquant les requêtes ICMP.	Désactivation autorisée du pare-feu par l'enseignant.
Erreur Network is unreachable au lancement	Absence d'accès direct à Internet.	Configuration du proxy 172.16.63.130:3128.
Nombreuses erreurs de modules	Clés API ou outils externes non configurés.	Interprétation prudente et utilisation des données effectivement collectées.
Scan du réseau très long	Le réseau 172.30.0.0/16 contient un grand nombre d'adresses.	Arrêt du test large et choix d'une cible web autorisée plus précise.

Conclusion

Ces travaux pratiques ont permis de construire un laboratoire de test d'intrusion fonctionnel, de vérifier que Kali Linux atteint Windows 7 et d'appliquer la première phase d'une méthodologie de pentest. La distinction entre reconnaissance passive et active a été mise en pratique et les actions ont été documentées dans CherryTree.

L'exercice 7 a été réalisé sur le serveur pédagogique btssiogap.com avec l'autorisation de l'enseignant. SpiderFoot a collecté principalement des informations DNS et réseau. La présence d'erreurs de modules a été analysée sans les confondre avec des vulnérabilités. Aucun accès non autorisé ni aucune exploitation n'a été effectué. Le travail respecte ainsi le périmètre prévu et fournit des preuves exploitables pour la suite du cours.